

**TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
TRUNG TÂM PHÁT TRIỂN CÔNG NGHỆ THÔNG TIN**

**ĐỒ ÁN CUỐI KỲ MÔN
NHẬP MÔN BẢO ĐẢM VÀ AN NINH THÔNG TIN**

Đề tài

**MINI PHISHING INSPECTOR: PHÁT HIỆN EMAIL LỪA ĐẢO BẰNG
PYTHON**

GIÁO VIÊN HƯỚNG DẪN
ThS. Hồ Hải

SINH VIÊN THỰC HIỆN:

Lê Hải Phúc (nhóm trưởng)	23730116
Nguyễn Lê Quý Phát	23730115
Nguyễn Thiên Trâm Anh	23730064

Hồ Chí Minh, tháng 8 năm 2025

MỤC LỤC

MỞ ĐẦU	1
Chương 1. Bối cảnh & động cơ	4
1.1. Vì sao e-mail phishing nguy hiểm	4
1.2. Tác động và số liệu (lý do cần công cụ phát hiện)	4
1.3. Mục tiêu đề tài và đóng góp	5
Chương 2. Môi đe dọa & “kill chain” của e-mail phishing	6
2.0. Khái quát	6
2.1. Kill chain rút gọn cho e-mail phishing	6
2.1.1. Lựa chọn mục tiêu (Targeting)	7
2.1.2. Soạn môi (Pretexting & Crafting)	7
2.1.3. Truyền tải (Delivery)	7
2.1.4. Khai thác/Thực thi (Exploitation/Execution)	8
2.1.5. Duy trì & Thu thập (Persistence/Exfiltration)	8
2.2. Công cụ/khung tấn công kẻ xấu thường dùng	9
2.2.1. Social-Engineer Toolkit (SET)	9
2.2.2. Evilginx2 (phishing proxy vượt 2FA truyền thống)	9
2.3. Từ e-mail đến malware: đường lây & hệ quả	9
2.3.1. Con đường lây nhiễm phổ biến	9
2.3.2. Các dòng mã độc thường gặp & tác động	10
2.3.3. Dấu hiệu sớm mà Mini Phishing Inspector có thể phát hiện	10
2.4. Kết nối về thiết kế công cụ	10
Chương 3. Thiết kế hệ thống “Mini Phishing Inspector”	11
3.1. Kiến trúc & tiêu chí phát hiện (heuristics + kiểm tra header)	11
3.1.1. Tổng quan kiến trúc	11
3.1.2. Bộ tiêu chí phát hiện (heuristics) theo từng lớp	11
3.2. Chức năng chính & tổ chức mã nguồn Python (phiên bản mini)	12
3.2.1. header_check.py — Phân tích đầu thư	12
3.2.2. link_inspector.py — Trích & soi URL	13
3.2.3. attachment_policy.py — Chính sách tệp đính kèm	13
3.2.4. scorer.py & cli.py — Hợp nhất & báo cáo	13
3.3. Đánh giá: điểm mạnh & giới hạn	14
3.3.1. Điểm mạnh	14
3.3.2. Giới hạn	14
3.3.3. Hướng khắc phục/nghiên cứu tiếp	14
Chương 4. Triển khai & demo Python	15
4.1. Bộ dữ liệu demo & kịch bản kiểm thử	15
4.2. Quy trình chạy công cụ	16
4.3. Thang điểm & quyết định	17
4.4. Đánh giá mini trên bộ mẫu (Precision/Recall & checklist)	18

4.5. Nhật ký (log).....	18
4.6. Tải lập thí nghiệm & an toàn.....	19
4.7. Ảnh xạ kết quả demo ↔ kill chain ↔ biện pháp.....	20
Kết luận chương.....	20
CHƯƠNG 5. PHÒNG THỦ ĐA LỚP.....	20
5.1. Lớp e-mail: xác thực miền & chính sách gateway.....	21
5.1.1. Mục tiêu.....	21
5.1.2. Xác thực miền gửi: SPF/DKIM/DMARC.....	21
5.1.3. Chính sách tại e-mail gateway.....	21
5.2. Lớp người dùng văn phòng: nhận diện & thói quen an toàn.....	22
5.2.1. Mục tiêu.....	22
5.2.2. Bộ quy tắc “10 giây soi thư”.....	22
5.2.3. Thói quen bắt buộc.....	23
5.3. Lớp mạng: giảm rủi ro MITM/Evil-Twin khi nhấp liên kết.....	23
5.3.1. Rủi ro chính.....	23
5.3.2. Biện pháp kỹ thuật.....	23
5.3.3. Check-list “đi công tác”.....	24
5.4. Lớp danh tính (Identity): tăng cường xác thực đăng nhập.....	24
5.4.1. Khái quát.....	24
5.4.2. Khuyến nghị theo mức bảo vệ.....	24
5.5. Quy trình ứng phó sự cố “nhẹ – nhanh – rõ”.....	25
5.6. Kết nối “cảnh báo → hành động”.....	25
Kết luận chương.....	25
Chương 6. Kết quả, hạn chế & hướng phát triển.....	26
6.1. Tóm tắt kết quả demo & chỉ số.....	26
6.1.1. Thiết lập thí nghiệm.....	26
6.1.2. Kết quả theo từng mẫu.....	26
6.1.3. Đóng góp theo từng mô-đun.....	27
6.2. Phân tích sai số.....	27
6.2.1. Tình huống dễ FP.....	27
6.2.2. Tình huống dễ FN (lọt lưới).....	28
6.3. Hạn chế của phiên bản hiện tại.....	28
6.4. Hướng phát triển.....	28
6.4.1. Nâng cấp phát hiện (kỹ thuật).....	28
6.4.2. Nâng cấp trải nghiệm & vận hành.....	29
6.5. Quản trị rủi ro, đạo đức & quyền riêng tư.....	29
KẾT LUẬN.....	30
TÀI LIỆU THAM KHẢO.....	31

MỞ ĐẦU

Bối cảnh

Trong kỷ nguyên số, e-mail vẫn là kênh trao đổi chính của cá nhân và tổ chức. Lợi thế phổ cập và chi phí thấp cũng khiến e-mail trở thành mục tiêu ưa thích của kẻ tấn công, đặc biệt qua hình thức phishing (giả mạo để chiếm đoạt thông tin/chi tiền/chiếm tài khoản). Mặc dù các hệ thống lọc thư rác ngày càng mạnh, thủ pháp lừa đảo cũng liên tục thích nghi: giả mạo miền gửi (spoofing), tên miền na ná/IDN homograph, liên kết bị che (shortener/redirect), hay tệp đính kèm có macro.

Với sinh viên và người dùng văn phòng, rủi ro thường xuất hiện ở “cú nhấp chuột đầu tiên”: mở liên kết/đính kèm trước khi kịp kiểm tra nguồn gửi. Do đó, bên cạnh các giải pháp doanh nghiệp, cần có một công cụ nhẹ, dễ hiểu, chạy cục bộ để soi nhanh e-mail và đưa ra cảnh báo có giải thích (explainable), giúp chặn sớm ngay từ phía người dùng cuối.

Vấn đề & câu hỏi nghiên cứu

Bài báo cáo tập trung vào câu hỏi: *Có thể xây dựng một công cụ Python tối giản, dựa trên các dấu hiệu (heuristics) để giải thích, để phát hiện sớm những đặc trưng điển hình của e-mail phishing hay không?*

Cụ thể:

- Làm thế nào để kiểm tra tiêu đề (From/Reply-To/Return-Path) và kết quả xác thực (SPF/DKIM/DMARC) nhằm phát hiện dấu hiệu giả mạo nguồn gửi?
- Làm thế nào để soi liên kết trong nội dung (mismatch text↔href, lookalike/IDN, shortener, đường dẫn nhảy cảm như /login, /verify) một cách tin cậy nhưng vẫn đơn giản?
- Làm thế nào để nhận diện nhanh tệp đính kèm rủi ro (nhóm macro/thực thi) và đưa khuyến nghị thao tác an toàn?
- Kết quả phát hiện có thể được hợp nhất và chấm điểm rủi ro (LOW/MEDIUM/HIGH) ra sao để người dùng dễ quyết định?

Mục tiêu

(1) Thiết kế và hiện thực Mini Phishing Inspector gồm 3 mô-đun:

- Header Analyzer: so nguồn gửi, phân tích SPF/DKIM/DMARC;
- URL/Link Inspector: phát hiện text≠href, IDN/Unicode, lookalike, shortener, path nhảy cảm;
- Attachment Policy: gắn cờ đuôi .docm/.xlsm/.exe/....

(2) Xây dựng pipeline chấm điểm theo trọng số heuristic, xuất cảnh báo có giải thích kèm khuyến nghị thao tác;

(3) Demo tái lập trên bộ e-mail mẫu an toàn (độc hại/không độc hại) và báo cáo chỉ số minh họa;

(4) Liên kết cảnh báo công cụ với phòng thủ đa lớp (gateway, người dùng, mạng, danh tính) để đề xuất chính sách tổng thể.

Phạm vi & giới hạn

- Công cụ chạy cục bộ, xử lý tĩnh nội dung/tiêu đề e-mail ở dạng .eml/văn bản; không tải nội dung bên ngoài, không thực thi tệp đính kèm, không sandbox động.
- Không dùng học máy; chỉ dùng heuristics nhằm dễ giải thích và phù hợp phạm vi học phần.
- Bộ dữ liệu demo là mẫu giả lập an toàn, phục vụ minh họa; khi triển khai thực tế cần bổ sung dữ liệu thật và cơ chế giảm FP/FN (whitelist, kiểm DNS trực tiếp, TI...).

Phương pháp tiếp cận

- Mô hình hoá theo kill chain của e-mail phishing: *Lure/Delivery* → *Execution* → *Collection*, từ đó chọn chỉ dấu kỹ thuật tương ứng cho từng mô-đun.
- Thiết kế hướng giải thích (explainable heuristics): mỗi cảnh báo đều kèm “lý do” (ví dụ: “*Text chứa vietcombank.com.vn nhưng href trỏ fake-bank.site*”).
- Thực nghiệm có kiểm soát: ba kịch bản độc hại phổ biến (spoofing, link giả, macro) và hai e-mail hợp pháp để ước lượng FP trên bộ nhỏ; báo cáo Precision/Recall mini.

Ý nghĩa & thực tiễn

- Giáo dục & nhận thức: giúp người học “thấy tận mắt” các dấu hiệu kỹ thuật và hình thành thói quen an toàn trước khi nhấp/mở.
- Kỹ thuật: khung mô-đun rõ ràng, dễ mở rộng (DNS/TI live check, URL multi-hop, ML nhẹ, GUI/plugin).
- Chính sách: cảnh báo từ công cụ được ánh xạ trực tiếp sang biện pháp ở gateway/endpoint/MFA, hỗ trợ xây dựng phòng thủ đa lớp.

Đóng góp chính của báo cáo

- Đề xuất và hiện thực công cụ Python tối giản nhưng đủ hữu dụng, có giải thích, phù hợp phạm vi học phần.

- Bộ demo tái lập + checklist thao tác an toàn + mapping cảnh báo → chính sách.
- Phân tích hạn chế và lộ trình nâng cấp để tiến tới môi trường thực tế (DNS/TI/ML/GUI).

Cấu trúc báo cáo

- **Chương 1:** Bối cảnh & động cơ.
- **Chương 2:** Môi đe dọa & kill chain của e-mail phishing.
- **Chương 3:** Thiết kế hệ thống Mini Phishing Inspector.
- **Chương 4:** Triển khai & demo Python.
- **Chương 5:** Phòng thủ đa lớp và khuyến nghị vận hành.
- **Chương 6:** Kết quả, hạn chế & hướng phát triển.
- **Phụ lục:** Bộ e-mail mẫu, hình minh họa, checklist người dùng, ghi chú an toàn mạng.

Chương 1. Bối cảnh & động cơ

1.1. Vì sao e-mail phishing nguy hiểm

Trong môi trường số hoá, e-mail vẫn là kênh giao tiếp cốt lõi của cá nhân, cơ sở giáo dục và doanh nghiệp. Chính vì mức độ phổ cập này, e-mail trở thành “bề mặt tấn công” lý tưởng cho kẻ xấu. E-mail phishing được hiểu là hành vi giả mạo danh tính (tổ chức/cá nhân đáng tin cậy) qua thư điện tử nhằm dẫn dụ nạn nhân tiết lộ thông tin nhạy cảm (mật khẩu, mã OTP, dữ liệu thẻ) hoặc thực thi hành vi rủi ro (nhấp vào liên kết độc hại, mở tệp đính kèm có mã độc). Về bản chất, phishing khai thác tâm lý tin cậy và thao túng nhận thức — chỉ cần một cú nhấp chuột sai, chuỗi rủi ro có thể lan từ lộ lọt dữ liệu tới chiếm quyền tài khoản, thậm chí phát tán mã độc trong nội bộ.

Những năm gần đây, kỹ thuật phishing đã tinh vi hơn cả về hình thức lẫn công cụ hỗ trợ. Ngoài việc giả mạo địa chỉ gửi (spoofing) và “mượn uy tín” thương hiệu, kẻ tấn công còn:

- dùng mạng botnet để phát tán quy mô lớn;
- dựng trang đăng nhập giả có giao diện gần như bản thật (look-and-feel cloning);
- lợi dụng tên miền tương tự/homograph (ví dụ ký tự Unicode/Punycode) để đánh lừa người xem;
- tận dụng AI/LLM để soạn nội dung tự nhiên, đúng ngữ cảnh, giảm lỗi chính tả và tăng độ thuyết phục;
- đính kèm tệp văn phòng bật macro, hoặc nhúng đường dẫn tải mã độc gián tiếp.

Sự “lai ghép” giữa thủ pháp kỹ thuật và thao túng tâm lý khiến việc nhận diện thủ công trở nên khó khăn. Đây là lý do cần các công cụ soi kiếm nhanh ngay trên máy người dùng, giúp phát hiện chỉ dấu rủi ro trước khi hành vi nguy hiểm diễn ra.

1.2. Tác động và số liệu (lý do cần công cụ phát hiện)

Các tổng kết an ninh mạng cho thấy phishing luôn nằm trong nhóm mối đe dọa phổ biến nhất và còn tăng theo thời gian. Trong giai đoạn 2016–2021, tỉ lệ người dùng báo cáo thư nghi ngờ có xu hướng tăng (phản ánh nhận thức tốt hơn), nhưng tỉ lệ nhấp vào liên kết lừa đảo cũng nhích lên theo — nghĩa là vẫn còn khoảng trống giữa nhận biết và hành động an toàn. Ở góc độ thiệt hại, các báo cáo thường niên như FBI Internet Crime Report 2022 ghi nhận phishing đóng góp một phần đáng kể vào tổng thiệt hại do tội phạm mạng, với chi phí tổn thất cộng dồn lên tới hàng chục triệu USD

chỉ riêng danh mục này, trong bối cảnh tổng thiệt hại mọi loại hình tấn công đạt mức hàng tỷ USD.

Các con số trên cho thấy:

- Phổ biến: phishing chạm tới mọi đối tượng — từ sinh viên, nhân viên văn phòng tới doanh nghiệp nhỏ.
- Tổn thất hữu hình: thất thoát tài chính trực tiếp, chi phí khắc phục sự cố, gián đoạn vận hành.
- Tổn thất vô hình: suy giảm uy tín, mất lòng tin vào dịch vụ số, ảnh hưởng lâu dài tới thương hiệu.

Vì vậy, bên cạnh đào tạo nhận thức, rất cần một cách tiếp cận công cụ hoá: tự động kiểm tra header, liên kết và tệp đính kèm để đưa ra cảnh báo sớm, từ đó giảm xác suất người dùng thực hiện hành vi rủi ro.

1.3. Mục tiêu đề tài và đóng góp

Đề tài tập trung xây dựng Mini Phishing Inspector — một công cụ dòng lệnh (CLI) gọn nhẹ viết bằng Python, chạy cục bộ, giúp người dùng soi nhanh e-mail nghi vấn. Cụ thể:

Mục tiêu nghiên cứu

1. Mô hình hoá chỉ dấu rủi ro của e-mail phishing theo ba trụ cột:
 - Tiêu đề/đầu thư (headers): so khớp From ↔ Reply-To/Return-Path, đọc trường Authentication-Results để ghi nhận dấu vết SPF/DKIM/DMARC (pass/fail/none).
 - Liên kết (URLs): trích xuất và kiểm tra Punycode/IDN, tên miền “na ná” (khoảng cách Levenshtein), shortener, IP-host, và trường hợp text hiển thị ≠ URL thực.
 - Tệp đính kèm (attachments): gắn cờ phân mở rộng rủi ro (ví dụ .exe, .js, .vbs, .scr, .docm/.xlsm, .zip) và nhấn mạnh chính sách chặn macro tải từ Internet.
2. Thiết kế thang điểm rủi ro minh bạch (LOW / MEDIUM / HIGH), giải thích được lý do gắn cờ (tính giải trình/giải thích).
3. Minh họa theo “kill chain”: đặt từng quy tắc vào mắt xích phù hợp (Delivery / Lure / Execution) để thấy giá trị chặn sớm.
4. Thực nghiệm có kiểm soát trên bộ .eml giả lập an toàn (bình thường vs. nghi vấn), ghi nhận cảnh báo, thảo luận sai số (false positive/negative).

Đóng góp dự kiến

- Công cụ Python nhỏ gọn, không phụ thuộc Internet, có thể dùng ngay trong bối cảnh học phần *Nhập môn Bảo đảm & An ninh thông tin* hoặc ở môi trường văn phòng.
- Bộ tiêu chí phát hiện có thể diễn giải, thuận lợi cho giảng dạy: sinh viên thấy rõ mỗi cảnh báo đến từ quy tắc nào, gắn với mắt xích nào của kill chain.
- Checklist 1 trang cho người dùng (đọc nhanh – làm được ngay): kiểm tra người gửi, soi liên kết, xử lý tệp đính kèm, bước ứng phó khi nghi ngờ.
- Khuyến nghị phòng thủ đa lớp: ở lớp e-mail (SPF/DKIM/DMARC, banner cảnh báo), lớp endpoint (AV/EDR, chặn macro từ Internet), lớp danh tính (MFA), và đào tạo nhận thức.

Tóm lại, đề tài hướng tới một lời giải thực dụng: biến tri thức về phishing thành bộ quy tắc kiểm tra tự động kèm công cụ minh họa rõ ràng, giúp giảm rủi ro trước khi hành vi nguy hiểm xảy ra và góp phần xây dựng thói quen an toàn cho người dùng phổ thông.

Chương 2. Mối đe dọa & “kill chain” của e-mail phishing

2.0. Khái quát

Phishing qua e-mail là cách kẻ tấn công mượn uy tín (thương hiệu/cá nhân) để dẫn dụ người nhận tiết lộ thông tin hoặc thực hiện hành vi rủi ro (nhấp liên kết, mở tệp đính kèm). Điểm mạnh của kỹ thuật này nằm ở tâm lý học (gấp gáp, sợ hãi, phần thưởng) kết hợp thủ pháp kỹ thuật (giả mạo địa chỉ gửi, tên miền giống 99%, tệp văn phòng bật macro...). Để hiểu cách phòng thủ hiệu quả, cần “trải phẳng” hành vi của đối thủ theo kill chain—chuỗi các mắt xích từ chuẩn bị đến khai thác—từ đó xác định điểm chặn sớm mà công cụ *Mini Phishing Inspector* có thể can thiệp.

2.1. Kill chain rút gọn cho e-mail phishing

(1) Lựa chọn mục tiêu → (2) Soạn mail → (3) Truyền tải (Delivery) → (4) Khai thác/Thực thi (Exploitation/Execution) → (5) Duy trì/Thu thập (Persistence/Exfiltration)

2.1.1. Lựa chọn mục tiêu (Targeting)

- **Mục đích của kẻ tấn công:** thu thập địa chỉ e-mail, phân nhóm (khách hàng ngân hàng, nhân viên HR, sinh viên...), quan sát lịch sử kiện để chọn thời điểm dễ mắc bẫy.
- **Chỉ dấu thấy được ở phía người nhận:** hầu như không; đây là giai đoạn *trước giao tiếp*.
- **Hàm ý phòng thủ:** hạn chế lộ danh sách mail công khai; dùng alias theo ngữ cảnh (news@..., hiring@...).

2.1.2. Soạn môi (Pretexting & Crafting)

- **Thủ pháp diễn hình:** nội dung “khẩn/quan trọng”, đòi mật khẩu, xác minh tài khoản, thông báo đơn hàng/hóa đơn; văn phong ngày càng “*như thật*” nhờ công cụ AI.
- **Chỉ dấu trong e-mail:** tiêu đề thúc giục, nội dung đe dọa/khuyến mãi quá tốt; lỗi chính tả nay ít hơn nhưng vẫn có *pattern* ngôn ngữ lạ.
- **Công cụ của ta (điểm đặt quy tắc):** cảnh báo “ngôn ngữ thúc giục” ở mức tham khảo; trọng tâm vẫn là kiểm tra **header/URL/đính kèm** (phần 2.1.3–2.1.4).

2.1.3. Truyền tải (Delivery)

- **Cách thức phổ biến:**
 - **Giả mạo địa chỉ gửi (spoofing):** *display name* đúng thương hiệu nhưng **domain gửi** không khớp; From trông hợp lệ nhưng Return-Path/Reply-To khác.
 - **Liên kết độc hại** trong thân thư; **rút gọn link** (shortener) để che đích đến.
 - **Tên miền na ná/homograph (IDN/Punycode):** thay ký tự (l → I), dùng Unicode (xn--) để tạo domain “giống 99%”.
- **Chỉ dấu kỹ thuật trong header/nội dung:**
 - Authentication-Results/Received-SPF cho biết **SPF/DKIM/DMARC pass/fail/none**.
 - Liên kết trỏ tới **IP thô, TLD lạ, shortener** (bit.ly, t.co...), hoặc **Punycode**.
- **Điểm chặn của Mini Phishing Inspector:**
 - So khớp From ↔ Reply-To/Return-Path; đọc **SPF/DKIM/DMARC** từ header.

- Phân tích URL: phát hiện **IDN**, **lookalike** (khoảng cách Levenshtein), **shortener**, **IP-host**.

2.1.4. Khai thác/Thực thi (Exploitation/Execution)

- **Hai nhánh chính:**
 - **Nhấp liên kết** → trang đăng nhập giả → đánh cắp thông tin/phiên đăng nhập.
 - **Mở tệp đính kèm** (Word/Excel/PDF nặng script) → **macro/ActiveX** tải xuống & chạy mã độc.
- **Chỉ dấu trước khi bấm/mở:** phần mở rộng tệp rủi ro (.exe, .js, .vbs, .scr, .ps1, .docm/.xlsm, .zip), cảnh báo “Protected View/mark-of-the-web” của Office.
- **Điểm chặn của công cụ:** gắn **cờ đỏ** cho đuôi tệp nguy hiểm; khuyến cáo **chặn macro từ Internet** (policy/IT).

2.1.5. Duy trì & Thu thập (Persistence/Exfiltration)

- **Mục đích:** cấy chốt (persistence), đánh cắp cookie phiên, mở kênh điều khiển (C2), nén & rò rỉ dữ liệu.
- **Vai trò của công cụ:** *Mini Phishing Inspector* dừng ở **tiền thực thi**; giai đoạn sau do **EDR/AV/SIEM** đảm nhiệm. Tuy nhiên, **càng chặn sớm ở Delivery/Execution, rủi ro càng giảm**.

Bảng ánh xạ “kill chain → chỉ dấu → quy tắc phát hiện trong Mini Phishing Inspector”

Mất xích	Chỉ dấu/IOC thường gặp	Quy tắc phát hiện tương ứng
Delivery	SPF/DKIM/DMARC: fail/none; From ≠ Return-Path/Reply-To	Đọc Authentication-Results/Received-SPF; so khớp miền gửi
Delivery	URL Punycode/IDN (xn--); shortener ; IP-host	Trích xuất URL; bộ kiểm tra IDN/shortener/IP
Lure	Tên miền lookalike (paypal ↔ paypal)	Khoảng cách Levenshtein trên SLD + whitelist thương hiệu
Execution	Đuôi tệp rủi ro (.exe, .js, .vbs, .scr, .docm, .xlsm, .zip)	Bộ nhận diện phần mở rộng + cảnh báo policy macro

2.2. Công cụ/khung tấn công kẻ xấu thường dùng

2.2.1. Social-Engineer Toolkit (SET)

- **Tác dụng cho kẻ tấn công:** dựng kịch bản lừa đảo, tạo nội dung e-mail, trang giả để thu thập thông tin.
- **Ý nghĩa phòng thủ:** nhận diện mẫu nội dung có kịch bản (gọi hành động, gấp gáp), kiểm tra header nghiêm ngặt; triển khai banner cảnh báo ở gateway với thư ngoài tổ chức.

2.2.2. Evilginx2 (phishing proxy vượt 2FA truyền thống)

- **Cơ chế tổng quát (mức khái quát):** đứng giữa nạn nhân và trang thật như proxy nghịch, hiển thị giao diện hợp pháp nhưng đánh cắp phiên đăng nhập (cookies/tokens), vì thế có thể vượt qua OTP một lần.
- **Hàm ý phòng thủ:**
 - Ưu tiên MFA chống phishing (FIDO2/WebAuthn) thay vì OTP qua SMS/TOTP khi bảo vệ tài khoản quan trọng.
 - Theo dõi bất thường phiên (IP, thiết bị, địa lý).
 - Tăng cường DMARC + huấn luyện để giảm xác suất nạn nhân truy cập trang giả ngay từ đầu.

2.3. Từ e-mail đến malware: đường lây & hệ quả

2.3.1. Con đường lây nhiễm phổ biến

1. Nhấp liên kết trong e-mail → chuyển tới trang đăng nhập giả hoặc bộ tải mã độc (drive-by download).
2. Mở tệp đính kèm (Office/PDF/Script) → kích hoạt macro/script → tải & thực thi mã độc.
3. Chuỗi kế tiếp: tạo chốt bền vững (persistence), liên lạc máy chủ C2, thu thập & rò rỉ dữ liệu.

2.3.2. Các dòng mã độc thường gặp & tác động

- **Trojan/Spyware**: ngụy trang phần mềm hữu ích, mở backdoor, đánh cắp thông tin; khó phát hiện nếu người dùng tự cấp quyền.
- **Ransomware**: mã hoá dữ liệu, đòi tiền chuộc; chi phí phục hồi lớn, rủi ro mất mát dài hạn.
- **Worm/Network-propagating Malware**: tự lan trong mạng nội bộ, gây tắc nghẽn và bùng phát nhanh.
- **Keylogger/Stealer**: ghi phím, đánh cắp mật khẩu, cookie phiên—đặc biệt nguy hiểm sau khi nạn nhân đăng nhập vào các dịch vụ.

2.3.3. Dấu hiệu sớm mà Mini Phishing Inspector có thể phát hiện

- Ở Delivery/Lure:
 - Header xác thực bất thường (SPF/DKIM/DMARC thất bại/không có).
 - Liên kết che dấu đích đến (shortener), Punycode/IDN, miền “na ná”.
- Ở Execution (trước khi chạy mã độc):
 - Đuôi tệp có nguy cơ cao (.exe, .js, .vbs, .scr, .ps1, .docm/.xlsm, .zip).
 - Gợi ý “Mark-of-the-Web/Protected View”: nếu tệp tải từ Internet, Office sẽ chặn macro—khuyến khích giữ nguyên mặc định chặn.

2.4. Kết nối về thiết kế công cụ

Từ phân tích kill chain và thủ pháp phổ biến, *Mini Phishing Inspector* sẽ tập trung vào ba trục phát hiện có thể kiểm tra tĩnh:

1. Header: so khớp miền gửi, ghi nhận SPF/DKIM/DMARC.
2. URL: trích xuất—phát hiện IDN/Lookalike/Shortener/IP-host—so khớp text hiển thị ≠ đích thật.
3. Đính kèm: nhận diện đuôi rủi ro và đưa ra khuyến cáo policy (chặn macro từ Internet).

Mỗi cảnh báo đều được gắn nhãn mức xích kill chain tương ứng (Delivery/Lure/Execution) và cộng vào thang điểm rủi ro minh bạch (LOW/MEDIUM/HIGH). Cấu phần này chính là “xương sống” để các chương tiếp theo mô tả kiến trúc, cài đặt Python, bộ dữ liệu thử nghiệm và kết quả.

Chương 3. Thiết kế hệ thống “Mini Phishing Inspector”

Mục tiêu của chương này là biến những dấu hiệu kỹ thuật đã phân tích ở Chương 2 thành kiến trúc, tiêu chí phát hiện và các mô-đun Python cụ thể, bảo đảm: (i) chạy cục bộ, (ii) không cần Internet, (iii) giải thích được vì sao một email bị gắn cờ, và (iv) dễ mở rộng cho các bài thực hành sau.

3.1. Kiến trúc & tiêu chí phát hiện (heuristics + kiểm tra header)

3.1.1. Tổng quan kiến trúc

Hệ thống được tổ chức theo pipeline 3 lớp tương ứng với các mắt xích sớm trong kill chain:

1. Header Analyzer → 2) URL/Content Inspector → 3) Attachment Policy Checker → Risk Scorer & Report

Luồng xử lý: nạp file .eml → trích xuất cấu trúc (header, thân thư dạng text/HTML, tệp đính kèm) → áp các quy tắc (heuristics) ở từng lớp → gom chỉ dấu (IOC/IOA) → chấm điểm rủi ro (LOW/MEDIUM/HIGH) kèm lời giải thích.

Nguyên tắc thiết kế: “chặn sớm – giải thích rõ – dễ mở rộng.” Mỗi cảnh báo đều nêu được *quy tắc nào kích hoạt* và *mắt xích kill chain* nó đang “chặn”.

3.1.2. Bộ tiêu chí phát hiện (heuristics) theo từng lớp

A) Lớp Header (Delivery)

Mục tiêu: phát hiện giả mạo miền gửi và bất thường xác thực.

- So khớp danh tính gửi: From ↔ Reply-To ↔ Return-Path (khác miền → cảnh báo).
- Dấu vết xác thực: đọc chuỗi Authentication-Results/Received-SPF trong header để ghi nhận SPF/DKIM/DMARC *pass/fail/none/softfail* (đây là *đọc kết quả đã được máy chủ thư ghi lại*, không truy DNS).
- Không nhất quán tên hiển thị: *display name* chứa tên thương hiệu nổi tiếng nhưng miền gửi không thuộc thương hiệu đó.
- Dấu hiệu chuyển tiếp bất thường: chuỗi Received: dài, vòng vèo qua các host “lạ” (điểm cảnh báo nhẹ, chỉ tham khảo).

B) Lớp Nội dung & Liên kết (Delivery/Lure)

Mục tiêu: ngăn người dùng bấm nhầm liên kết.

- Text $\neq$ URL đích: *anchor text* hiển thị và href không trùng miền/đích (cảnh báo mạnh).
- Tên miền “na ná”: so SLD (second-level domain) với danh sách thương hiệu phổ biến bằng khoảng cách Levenshtein ($\approx 1-2$ ký tự $\rightarrow$ cảnh báo).
- IDN/Homograph: hostname bắt đầu xn-- hoặc chứa ký tự Unicode lạ $\rightarrow$ có nguy cơ homograph.
- Shortener/IP-host: miền rút gọn (bit.ly, t.co, v.v.) hoặc đích là địa chỉ IP $\rightarrow$ tăng điểm rủi ro.
- TLD/ký hiệu bất thường: TLD hiếm hoặc “không ăn nhập” ngữ cảnh (ví dụ .zip, .mov) $\rightarrow$ cảnh báo nhẹ.
- Tín hiệu ngôn ngữ thúc giục: cụm như “xác minh ngay”, “tài khoản sẽ bị khoá”... $\rightarrow$ tín hiệu ngữ cảnh, chỉ cộng điểm nhỏ (tránh dương tính giả).

C) Lớp Tập đính kèm (Execution)

Mục tiêu: chặn trước khi mở tệp có nguy cơ.

- Phần mở rộng rủi ro cao: .exe, .js, .vbs, .scr, .bat, .cmd, .ps1, .apk, .jar, .dll, .msi.
- Tệp Office bật macro: .docm, .xlsm hoặc tệp nén .zip/.rar chứa thực thi $\rightarrow$ cảnh báo mạnh.
- Gợi ý chính sách: nhắc “Block macros from the Internet” và mở trong Protected View/Sandbox (hành động khuyến nghị kèm cảnh báo).

D) Thang điểm rủi ro hợp nhất

- Mỗi quy tắc gán trọng số theo mức độ nghiêm trọng (ví dụ: DMARC=fail +2, From $\neq$ Return-Path +1, IDN +2, Levenshtein=1 +2, ext=.docm +2, shortener +1...).
- Risk level: 0–2: LOW, 3–4: MEDIUM, ≥ 5 : HIGH.
- Báo cáo luôn giải thích: “URL dùng Punycode”, “Reply-To khác From”, “Đính kèm .docm”... và gắn mắt xích (Delivery/Lure/Execution).

3.2. Chức năng chính & tổ chức mã nguồn Python (phiên bản mini)

3.2.1. header_check.py — Phân tích đầu thư

Đầu vào: đối tượng email.message.EmailMessage (đã parse từ .eml).

Đầu ra:

- indicators: danh sách chỉ dấu, ví dụ ("From", "Support <support@example.com>"), ("Auth", "SPF=fail, DKIM=none, DMARC=none").

- warnings: cảnh báo dạng câu giải thích, ví dụ “Reply-To khác miền với From (abc.co ≠ acb.co)”.
- score: điểm cộng rủi ro.

Kiểm tra chính:

- Tách From/Reply-To/Return-Path → so miền.
- Trích Authentication-Results/Received-SPF → suy ra trạng thái SPF/DKIM/DMARC.
- Heuristic tên hiển thị vs miền thương hiệu (brand-display mismatch).

3.2.2. link_inspector.py — Trích & soi URL

Đầu vào: thân thư ở dạng text/HTML.

Đầu ra: danh sách URL, cảnh báo, điểm cộng.

Bước xử lý:

- **Trích xuất URL** bằng regex an toàn cho text/HTML.
- **Anchor-mismatch:** nếu có cặp *text/href* trong HTML → so miền.
- **Chuẩn hoá hostname**, kiểm tra:
 - xn-- → **IDN/Punycode**;
 - **shortener** (bit.ly, t.co, tinyurl, ...);
 - **IP-host**;
 - **lookalike:** đo Levenshtein giữa **SLD** và tên thương hiệu phổ biến (paypal, google, microsoft, apple, amazon, ...).

3.2.3. attachment_policy.py — Chính sách tệp đính kèm

Đầu vào: danh sách msg.iter_attachments().

Đầu ra: tên tệp, loại MIME, cảnh báo, điểm cộng.

Kiểm tra chính:

- Phân mở rộng **thực thi/script & Office macro**.
- Tệp nén chứa thực thi (nếu đọc được tên file con) → cảnh báo mạnh.

3.2.4. scorer.py & cli.py — Hợp nhất & báo cáo

- **scorer.py:** gom cảnh báo từ 3 mô-đun, cộng điểm theo bảng trọng số, gán level **LOW/MEDIUM/HIGH** và *tag kill chain*.
- **cli.py:** giao diện dòng lệnh:
 - python cli.py sample.eml → in **bảng chỉ dấu + Warnings + Risk level**.
 - Tuỳ chọn --json xuất **JSON**, --csv ghi **CSV** (giúp chấm/đối chiếu).

- In **khuyến nghị hành động** theo từng cảnh báo (ví dụ: bật DMARC, không mở .docm, kiểm tra domain trong trình duyệt...).

3.3. Đánh giá: điểm mạnh & giới hạn

3.3.1. Điểm mạnh

- Thực dụng & dễ triển khai: chạy cục bộ, không cần Internet, phụ thuộc chuẩn .eml → phù hợp phòng máy và môi trường hạn chế.
- Minh bạch & giải thích được: mỗi cảnh báo gắn quy tắc cụ thể và mắt xích kill chain → dễ học, dễ chấm.
- Tài nguyên thấp: chỉ dùng thư viện chuẩn Python; có thể chạy trên máy cấu hình phổ thông.
- Mô-đun hoá: dễ thêm quy tắc mới (ví dụ, danh mục shortener/TLD, thương hiệu), dễ whitelist theo bối cảnh lớp/học viện.

3.3.2. Giới hạn

- Không phân tích động/sandbox: không chạy file đính kèm để quan sát hành vi → chỉ “chặn sớm” bằng nhận diện tĩnh.
- Không dựa vào Threat Intelligence thời gian thực: chưa tra cứu miền/URL trong danh sách đen cộng đồng.
Khó phát hiện spear-phishing tinh vi: nội dung rất sát ngữ cảnh (cá nhân hoá) có thể vượt qua heuristics ngôn ngữ.
- Bypass 2FA kiểu proxy (Evilginx): công cụ chỉ “chặn trước khi bấm”, không giám sát sau đăng nhập.

3.3.3. Hướng khắc phục/nghiên cứu tiếp

- Bổ sung kiểm tra DNS sống (tùy chọn có mạng): truy SPF/DKIM/DMARC, A/AAAA/CNAME.
- Tích hợp nguồn TI (OSINT): block-list miền/URL, danh mục TLD rủi ro.
- Mở rộng mô hình học máy nhẹ: vector hoá đặc trưng URL/ngôn ngữ để xếp hạng rủi ro.
- Giao diện đồ hoạ/tiện ích trình duyệt: biến CLI thành GUI hoặc extension, tăng tính dùng được hằng ngày.
- Chính sách tổ chức: kết hợp banner cảnh báo e-mail ngoài tổ chức, DMARC p=quarantine/reject, Block macros from the Internet, MFA chống phishing (FIDO2/WebAuthn).

Chương 4. Triển khai & demo Python

Mục tiêu của chương này là đưa thiết kế ở Chương 3 vào vận hành bằng một bộ công cụ Python tối giản, chạy cục bộ, có khả năng soi nhanh e-mail ở ba trục: Header → Liên kết → Tập đính kèm, sau đó hợp nhất cảnh báo và chấm điểm rủi ro. Phần demo được xây dựng hoàn toàn bằng mẫu giả lập an toàn, không sử dụng mã độc thật.

4.1. Bộ dữ liệu demo & kịch bản kiểm thử

Để minh họa năng lực phát hiện, ta xây dựng **03 e-mail mẫu** dưới dạng .eml. Mỗi mẫu tái hiện một **kỹ thuật lừa phổ biến** đã phân tích trong Chương 2, đồng thời **an toàn** cho môi trường học thuật.

(E001) “Trúng thưởng” — giả mạo người gửi (spoofing)

- **Chủ đề:** Chúc mừng! Bạn đã trúng thưởng chương trình quay số may mắn
- **Người gửi hiển thị:** MegaLottery Support <support@megalottery.com>
- **Địa chỉ thật:** lottery.support@gmail.com (có ý sai chính tả miền)
- **Nội dung:** Hỏi thúc người nhận truy cập đường link để “nhận thưởng trong 24 giờ”.
- **Kỳ vọng phát hiện:**
 - **Header Analyzer** chỉ ra **không nhất quán** giữa From và Reply-To/Return-Path (nếu có).
 - Authentication-Results/Received-SPF **không đạt** hoặc **không có** (fail/softfail/none).
 - Rủi ro tổng thể: **cao** do spoofing + ngôn ngữ thúc giục.

(E002) “Xác minh tài khoản” — liên kết giả (lookalike/IDN/shortener)

- **Chủ đề:** Cảnh báo: Tài khoản ngân hàng của bạn sắp bị khóa
- **Người gửi hiển thị:** Ngân hàng Vietcombank <thongbao@vietcombank.com>
- **Địa chỉ thật:** secure.verify@vietcombank.com.vn (miền “na ná”)
- **Nội dung:** Đề nghị “xác minh ngay” qua một **liên kết ẩn**.
- **Kỳ vọng phát hiện:**
 - **Link Inspector** phát hiện **text** ≠ **href**, kiểm tra hostname: **lookalike** (Levenshtein≈1–2), **shortener** hoặc **IDN** (xn--...) nếu có.
 - Header có thể vẫn “đẹp” → minh họa: **nội dung/URL** mới là nơi bật cờ.

(E003) “Hóa đơn thanh toán” — tập đính kèm macro

- **Chủ đề:** Hóa đơn thanh toán Q4/2024 — KHẨN
- **Người gửi hiển thị:** Phòng Kế toán Công ty X <ketoan@congyx.com>
- **Đính kèm:** invoice_Q4_2024.docm (mẫu **giả lập**, không chứa macro thật)

- **Kỳ vọng phát hiện:**

- **Attachment Policy Checker** gắn cờ đỏ cho .docm (định dạng hỗ trợ macro).

Khuyến cáo hành động: **không bật Enable Content**, mở **Protected View/Sandbox**.

4.2. Quy trình chạy công cụ

Các tiện ích Python được tổ chức thành **ba mô-đun** tương ứng pipeline đã nêu; có thể gọi độc lập hoặc qua một cli.py hợp nhất.

Bước 1 — Phân tích header: `header_check.py`

Chức năng chính

- Trích các trường: From, Reply-To, Return-Path, Subject, Date.
- Đọc Authentication-Results/Received-SPF để ghi nhận SPF/DKIM/DMARC: pass/fail/softfail/none.
- So khớp miền giữa From ↔ Reply-To/Return-Path; đánh dấu display name mượn thương hiệu nhưng miền không khớp.

Đầu ra kỳ vọng (E001)

=== HEADER ANALYSIS: E001 ===

From: "MegaLottery Support" <lottery.support@gmail.com>

Subject: Chúc mừng bạn đã trúng thưởng...

Auth-Results: spf=fail; dkim=none; dmarc=none

Finding:

- Reply-To/Return-Path khác miền From
- Display name gọi thương hiệu, nhưng domain gửi không khớp

Risk contribution: +2 (SPF/DMARC fail) +1 (From ≠ Reply-To)

Bước 2 — Soi liên kết: `link_inspector.py`

Chức năng chính

- Trích toàn bộ URL từ nội dung text/HTML.
- Với HTML, so anchor text ↔ href để phát hiện text-link mismatch.
- Chuẩn hóa hostname, kiểm tra: IDN/Punycode (xn--), shortener, IP-host.
- Đo Levenshtein giữa SLD và danh mục thương hiệu phổ biến → phát hiện lookalike.

Đầu ra kỳ vọng (E002)

=== LINK ANALYSIS: E002 ===

Found 1 link:

- Text: "Xác minh tài khoản"
- Href: `hxxps://fake-bank.phishing.site/verify`

Checks:

- Text $\neq$ Href domain (mismatch)
- Domain not in official bank list
- Shortener/IDN: none

Risk contribution: +2 (mismatch) +2 (lookalike brand)

Bước 3 — Kiểm tra tệp đính kèm: `attachment_policy.py`

Chức năng chính

- Liệt kê tên tệp, MIME type; kiểm tra đuôi mở rộng.
- Gắn nhãn rủi ro cho nhóm thực thi/script (.exe, .js, .vbs, .scr, .ps1...), Office macro (.docm, .xlsm) và nén (.zip/.rar) chứa thực thi.
- Xuất khuyến nghị thao tác an toàn (Protected View, Sandbox, không bật macro).

Đầu ra kỳ vọng (E003)

=== ATTACHMENT ANALYSIS: E003 ===

Found attachment: invoice_Q4_2024.docm

MIME: application/vnd.ms-word.document.macroenabled.12

Risk contribution: +2 (.docm macro-enabled)

Advice: Không bật "Enable Content"; mở ở Protected View/Sandbox.

Hợp nhất & báo cáo: `cli.py`

- Gom indicators & warnings từ 3 mô-đun, chấm điểm trọng số và xếp hạng LOW/MEDIUM/HIGH.
- In bảng “chỉ dấu $\rightarrow$ quy tắc $\rightarrow$ mất xích kill chain” và khuyến nghị hành động theo từng cảnh báo.
- Tùy chọn --json/--csv để lưu kết quả phục vụ đối chiếu/chấm điểm.

4.3. Thang điểm & quyết định

Để minh bạch và nhất quán, sử dụng bảng **trọng số** tham khảo sau (có thể điều chỉnh trong file cấu hình):

- SPF/DMARC = fail/softfail +2
- From $\neq$ Reply-To/Return-Path +1
- Text $\neq$ Href (mismatch) +2
- IDN/Punycode (xn--) +2
- Lookalike (Levenshtein=1) +2 (=2 $\rightarrow$ +1)
- Shortener / IP-host +1
- Attachment .docm/.xlsm/.exe/.js/... +2
- Ngôn ngữ thúc giục/đe dọa +1 (nhẹ)

Ngưỡng quyết định

- 0–2 → **LOW** (không có chỉ dấu kỹ thuật rõ ràng)
- 3–4 → **MEDIUM** (khuyến nghị cảnh giác, kiểm tra lại miền/nguồn)
- ≥ 5 → **HIGH** (nguy cơ cao, **không** nhấp/ mở; báo cáo/quarantine)

4.4. Đánh giá mini trên bộ mẫu (Precision/Recall & checklist)

Với bộ 3 mẫu đều có dụng ý lừa, kỳ vọng:

- **TP (đúng phát hiện): 3**
- **FP (báo nhầm): 0** (không đưa e-mail hợp pháp vào bộ test)
- **FN (bỏ sót): 0**

Chỉ số

- **Precision** = $TP / (TP + FP) = 3 / 3 = 100\%$
- **Recall** = $TP / (TP + FN) = 3 / 3 = 100\%$

Bảng Checklist đối chiếu theo quy tắc

ID	Kịch bản	Header Check	Link Inspector	Attachment Policy	Tổng kết
E001	Trúng thưởng (spoofing)	Không đạt (SPF/DMARC fail; From≠Reply-To)	N/A	N/A	Không đạt
E002	Xác minh tài khoản (link giả)	Đạt (header “đẹp”)	Không đạt (text≠href; lookalike)	N/A	Không đạt
E003	Hóa đơn (macro)	Đạt	Đạt	Không đạt (.docm)	Không đạt

4.5. Nhật ký (log)

Ví dụ log rút gọn — header_check.py (E001)

[INFO] Parsing headers: E001.eml

From: "MegaLottery Support" <lottery.support@gmail.com>

Auth: spf=fail; dkim=none; dmarc=none

Warn: Reply-To domain != From domain (gmail.com ≠ megalottery.com)

Score +3 → Delivery

Ví dụ log rút gọn — link_inspector.py (E002)

[INFO] Extracting links: E002.eml

#1 Text="Xác minh tài khoản" Href="hxxps://fake-bank.phishing.site/verify"

Warn: Text/Href domain mismatch

Warn: Domain lookalike to known brands (Levenshtein=1)

Score +4 → Delivery/Lure

Ví dụ log rút gọn — attachment_policy.py (E003)

[INFO] Attachments: E003.eml

Found: invoice_Q4_2024.docm (macro-enabled)

Warn: High-risk extension .docm → Execution

Score +2

Báo cáo hợp nhất — cli.py

=== PHISHING INSPECTOR REPORT ===

[Indicators]

- SPF/DMARC: fail/none
- URL: text≠href, lookalike(SLD), no IDN
- Attachment: .docm (macro-enabled)

[Warnings]

- From ≠ Reply-To/Return-Path
- Suspicious link domain (fake-bank.phishing.site)
- High-risk attachment (.docm)

Risk Level: HIGH (score=7)

Recommendations:

- Không nhấp liên kết; xác minh miền trên trình duyệt gõ tay.
- Không mở hoặc mở ở Protected View; không bật macro.
- Báo cáo/quarantine theo quy trình đơn vị.

4.6. Tái lập thí nghiệm & an toàn

- Chuẩn bị môi trường: Python 3.x; không yêu cầu thư viện bên thứ ba.
- Nguồn dữ liệu: .eml do nhóm tự tạo; không sử dụng mã độc thật, không truy cập liên kết nguy hiểm.
- Thực hành an toàn:
 - Với tệp Office, luôn giữ Protected View và Block macros from the Internet.

- Không chuyển đổi hxxps thành https khi trình diễn.
- Nếu cần minh hoạ cơ chế AV, dùng chuỗi EICAR (chuẩn thử nghiệm vô hại) thay vì tệp độc hại.

4.7. Ảnh xạ kết quả demo ↔ kill chain ↔ biện pháp

- Delivery (E001/E002): phát hiện spoofing, SPF/DMARC fail, text≠href, lookalike/IDN/shortener
→ Biện pháp: DMARC p=quarantine/reject, banner cảnh báo mail ngoài; huấn luyện kiểm tra miền; chặn TLD/shortener rủi ro tại gateway.
- Execution (E003): phát hiện .docm/.xlsm
→ Biện pháp: chặn macro từ Internet, mở Protected View, triển khai EDR/AV ở đầu cuối.
- Danh tính (sau nhấp): đề xuất MFA chống phishing (FIDO2/WebAuthn) và giám sát bất thường phiên đăng nhập.

Kết luận chương

Bộ demo Python đã hiện thực hoá pipeline phát hiện tĩnh: từ header (xác thực miền gửi), qua URL (nhận diện lookalike/IDN/mismatch), tới đính kèm (đuôi rủi ro). Trên các kịch bản giả lập, công cụ thể hiện khả năng chặn sớm đúng với mục tiêu học phần: giảm xác suất nhấp/mở, cung cấp cảnh báo dễ hiểu, và đưa ra khuyến nghị hành động cụ thể. Các kết quả và log minh hoạ là cơ sở để sang Chương 5 tổng hợp, phân tích hạn chế, và đề xuất lộ trình nâng cấp (DNS live check, OSINT, ML nhẹ, GUI/Extension).

CHƯƠNG 5. PHÒNG THỦ ĐA LỚP

Mục tiêu chương: chuyên hoá kết quả phát hiện của *Mini Phishing Inspector* thành chính sách và biện pháp phòng vệ cụ thể ở nhiều tầng: E-mail → Người dùng → Mạng → Danh tính. Cách tiếp cận “phòng thủ đa lớp” (layered defense) giúp không phụ thuộc vào một hàng rào duy nhất, giảm xác suất sự cố ngay từ mắt xích Delivery/Lure/Execution trong kill chain, đồng thời bảo đảm có điểm tựa nếu một lớp bị vượt qua.

5.1. Lớp e-mail: xác thực miền & chính sách gateway

5.1.1. Mục tiêu

- Ngăn thư giả mạo tới hộp thư người dùng (trước khi người dùng phải tự phân biệt).
- Đánh dấu rủi ro ngay trong giao diện e-mail để người dùng “đọc là cảnh giác”.

5.1.2. Xác thực miền gửi: SPF/DKIM/DMARC

- SPF (Sender Policy Framework): khai báo địa chỉ IP/host được phép gửi thay mặt domain.
- DKIM (DomainKeys Identified Mail): ký số phần tiêu đề/nội dung; phía nhận xác minh chữ ký bằng khoá công khai trong DNS.
- DMARC (Domain-based Message Authentication, Reporting & Conformance): đặt chính sách khi SPF/DKIM không trùng khớp (alignment) — p=none | quarantine | reject — đồng thời gửi báo cáo cho chủ domain.

Khuyến nghị triển khai thực tế (lộ trình an toàn):

1. Bước 1 – Quan sát: DMARC p=none (thu thập báo cáo, chưa chặn).
2. Bước 2 – Cách ly: DMARC p=quarantine; pct=50 (cách ly 50% thư sai).
3. Bước 3 – Chặn cứng: DMARC p=reject (từ chối hẳn thư sai); xoá pct khi ổn định.
4. Lưu ý alignment: bảo đảm tên miền trong From trùng khớp (aligned) với bản ghi SPF/DKIM.

Liên hệ với công cụ: nếu *Mini Phishing Inspector* cảnh báo SPF/DKIM/DMARC = fail/none hoặc From $\neq$ Reply-To/Return-Path, đó là chỉ dấu cấu hình thiếu/không chuẩn ở phía người gửi, hoặc là thư giả mạo cần quarantine/reject ở gateway.

5.1.3. Chính sách tại e-mail gateway

- Banner cảnh báo “External”: tự động chèn vào thư từ bên ngoài; tô đậm khi thư yêu cầu đăng nhập, chuyển tiền, tải tệp.
- URL checking & time-of-click: kiểm tra/ghi log đường dẫn khi bấm, chặn TLD/miền rủi ro, cảnh báo IDN/Punycode.
- Attachment control: chặn hoặc cách ly .exe, .js, .vbs, .scr, .ps1, .iso; chuyển .docm/.xlsm vào sandbox; bật file-type detection (không chỉ dựa vào đuôi).
- Rate limiting/anti-spam: hạn chế thư bùng phát từ nguồn lạ; giảm tải cho người dùng tuyến cuối.

- DMARC quarantine/reject: tuân thủ chính sách domain người gửi; ghi nhận báo cáo để tinh chỉnh.

Bảng “Cảnh báo của công cụ → Hành động tại gateway”

Cảnh báo từ Mini Inspector	Ý nghĩa	Hành động gateway khuyến nghị
SPF/DKIM/DMARC = fail/none	Thư không chứng thực/không khớp miền	Quarantine/Reject theo DMARC; gắn banner rủi ro cao
From ≠ Reply-To/Return-Path	Dấu hiệu giả mạo/đánh tráo trả lời	Chặn/bổ sung cảnh báo “không phản hồi địa chỉ này”
IDN/Punycode (xn--)	Tên miền homograph	Cảnh báo/đổi màu liên kết; chặn nếu domain trong danh sách cấm
Text ≠ Href	Ngụy trang liên kết	Cảnh báo khi rê chuột; bật time-of-click check
.docm/.xlsm/.exe/...	Tệp nguy cơ cao	Chặn hoặc bắt buộc sandbox/Protected View

5.2. Lớp người dùng văn phòng: nhận diện & thói quen an toàn

5.2.1. Mục tiêu

- Giảm tỷ lệ nhấp (click-through rate) vào liên kết/tệp rủi ro.
- Tạo phản xạ an toàn trong 10–20 giây đầu khi đọc thư.

5.2.2. Bộ quy tắc “10 giây soi thư”

1. Nhìn người gửi: tên hiển thị ≠ miền tổ chức? From có khớp Reply-To?
2. Đọc banner/gắn cờ: thư từ External + yêu cầu đăng nhập/chuyển tiền → cảnh giác cao.
3. Rê chuột xem liên kết: text có khớp href? Có xn--/chuỗi lạ/shortener không?
4. Xem đính kèm: .docm/.xlsm/.exe? Nếu có → không mở trực tiếp.

5. Suy đoán ngữ cảnh: “khẩn cấp”, “bị khoá”, “trúng thưởng” → kiểm tra qua kênh thứ cấp (gọi điện/bộ phận CNTT).

5.2.3. Thói quen bắt buộc

- Mật khẩu & quản lý khoá: dùng trình quản lý mật khẩu; không tái sử dụng; bật MFA.
- Macro & tệp từ Internet: không bật “Enable Content”; dùng Protected View.
- Thiết bị rời: cấm cắm USB lạ; quét trước khi mở; áp dụng Device Control nếu có.
- Cập nhật & backup: hệ điều hành/ứng dụng luôn cập nhật; có backup định kỳ ngoại tuyến/ngoài site.
- Báo cáo sự cố 1-phút: phát hiện thư nghi ngờ → bấm “Report phishing” hoặc gửi mẫu .eml tới SOC/IT.

5.3. Lớp mạng: giảm rủi ro MITM/Evil-Twin khi nhấp liên kết

5.3.1. Rủi ro chính

- MITM (Man-in-the-Middle): kẻ tấn công đứng giữa phiên kết nối để nghe lén/chỉnh sửa dữ liệu.
- Evil-Twin: dựng điểm phát Wi-Fi giả (SSID giống/na ná) với tín hiệu mạnh, ép thiết bị tự động kết nối; từ đó đánh cắp phiên đăng nhập, trỏ DNS độc hại hoặc chèn nội dung.

5.3.2. Biện pháp kỹ thuật

- Ưu tiên WPA2-Enterprise/WPA3; tắt auto-connect với Wi-Fi công cộng.
- VPN bắt buộc khi ra ngoài; chính sách “no-VPN = no corporate access”.
- HTTPS-Only + kiểm tra chứng chỉ; bật DNS-over-HTTPS/DNSSEC nếu hạ tầng cho phép.
- Tách VLAN/Network segmentation cho khách/thiết bị BYOD; hạn chế *lateral movement*.
- Giám sát bất thường DNS/ARP; cảnh báo khi có ARP spoofing hoặc DNS poisoning.

5.3.3. Check-list “đi công tác”

- Dừng hotspot cá nhân thay vì Wi-Fi công cộng khi thao tác nhạy cảm.
- Nếu buộc dùng Wi-Fi công cộng: VPN ngay → kiểm tra ổ khoá HTTPS trước khi đăng nhập.
- Không đăng nhập tài khoản quan trọng từ máy/kiosk lạ.

5.4. Lớp danh tính (Identity): tăng cường xác thực đăng nhập

5.4.1. Khái quát

MFA (đa yếu tố) kết hợp biết (mật khẩu/PIN) + có (OTP, khoá bảo mật) + là (sinh trắc). Mục tiêu là giảm thiểu rủi ro ngay cả khi mật khẩu bị lộ do phishing.

5.4.2. Khuyến nghị theo mức bảo vệ

- Ưu tiên “phishing-resistant MFA”: FIDO2/WebAuthn (khoá bảo mật/Passkey) cho tài khoản trọng yếu (e-mail, quản trị, tài chính).
- TOTP (authenticator app) làm phương án dự phòng; hạn chế SMS OTP cho trường hợp bắt buộc (SIM-swap/phishing dễ lợi dụng).
- Step-up authentication: yêu cầu yếu tố bổ sung khi phát hiện đăng nhập bất thường (địa lý, thiết bị, thời gian).
- Quản trị phiên: rút ngắn TTL phiên nhạy cảm; vô hiệu hoá phiên khi đổi mật khẩu hoặc báo cáo bị nghi lộ cookie.

Bảng so sánh ngắn gọn các phương thức bảo mật

Phương thức	Chống phishing	Khả dụng	Lưu ý
Mật khẩu đơn thuần	Thấp	Cao	Không đủ; chỉ làm lớp đầu
OTP qua SMS	Thấp-Trung	Cao	Dễ bị chuyển hướng/SIM-swap
TOTP (app)	Trung	Tốt	Khá an toàn, phổ cập
FIDO2/WebAuthn	Cao	Tốt	Khuyến nghị cho tài khoản trọng yếu

5.5. Quy trình ứng phó sự cố “nhẹ – nhanh – rõ”

Dù đã phòng thủ đa lớp, vẫn cần **runbook** chuẩn để rút ngắn thời gian xử lý:

1. **Phát hiện/Báo cáo:** người dùng bấm “Report phishing” → mẫu .eml chuyển về SOC/IT.
2. **Khoanh vùng:** tạm **cách ly** thư tương tự (theo chủ đề/miền/IP); **thu hồi** khỏi hộp thư khác nếu có.
3. **Đổi thông tin xác thực:** yêu cầu **đổi mật khẩu**, thu hồi **token/phiên** bị nghi lộ; bật/siết **MFA**.
4. **Quét & khôi phục:** rà soát endpoint, logs DNS/Proxy; khôi phục dữ liệu từ **backup sạch** nếu cần.
5. **Thông báo & đào tạo lại:** tóm tắt sự cố, chỉ ra **dấu hiệu cần nhận biết**; cập nhật **chính sách gateway** (block domain, rule mới).
6. **Rút kinh nghiệm:** cập nhật **trọng số** trong *Mini Phishing Inspector* nếu thấy cần tăng/giảm mức cảnh báo cho một số chỉ dấu.

5.6. Kết nối “cảnh báo → hành động”

Cảnh báo trong báo cáo Python	Kill chain	Hành động người dùng	Hành động kỹ thuật
SPF/DMARC fail	Delivery	Không trả lời/không nhấp	Gateway quarantine/reject; theo dõi báo cáo DMARC
Text ≠ Href	Lure	Rê chuột kiểm tra; gõ tay domain	URL rewrite/time-of-click; block domain lookalike
IDN/Punycode	Lure	Dừng lại, kiểm tra domain chuẩn	Cảnh báo IDN; chặn TLD/domain rủi ro
.docm/.xlsm/.exe	Execution	Không mở; nếu bắt buộc → Protected View	Chặn/ sandbox; bật Block macros from the Internet
Shortener / IP-host	Delivery/Lure	Không bấm; yêu cầu gửi link rõ	Mở rộng danh sách shortener cấm; log & alert

Kết luận chương

Phòng thủ đa lớp không chỉ là “xếp thêm rào cản”, mà là liên kết có chủ đích giữa:

- Cảnh báo sớm từ *Mini Phishing Inspector* (tĩnh, chạy cục bộ),

- Chính sách gateway (lọc trước khi tới người dùng),
- Thói quen an toàn (giảm click/open),
- Hạ tầng mạng & danh tính (VPN, segment, MFA).

Khi các lớp này phối hợp nhịp nhàng, xác suất thành công của phishing giảm mạnh, thiệt hại (nếu có) cũng được khoanh vùng và khắc phục nhanh. Đây là nền tảng để sang Chương 6 tổng kết kết quả, phân tích hạn chế, và đề xuất lộ trình nâng cấp công cụ cũng như chính sách bảo vệ tổng thể.

Chương 6. Kết quả, hạn chế & hướng phát triển

Chương này tổng hợp kết quả chạy thử của Mini Phishing Inspector trên bộ mẫu giả lập an toàn (đã mô tả ở Chương 4), phân tích điểm mạnh – điểm yếu theo từng chiều phát hiện (Header/URL/Đính kèm), và đề xuất lộ trình nâng cấp ở cả mức công cụ lẫn chính sách vận hành. Lưu ý: các số liệu dưới đây đến từ bộ dữ liệu demo do nhóm tự xây dựng, không phải từ nguồn công bố bên ngoài.

6.1. Tóm tắt kết quả demo & chỉ số

6.1.1. Thiết lập thí nghiệm

- Môi trường: Python 3.x, không phụ thuộc Internet, thư viện chuẩn.
- Tập mẫu .eml: 03 e-mail giả lập an toàn, mỗi mẫu đại diện một kỹ thuật thường gặp:
 - E001: “Trúng thưởng” — spoofing (giả mạo người gửi, SPF/DMARC không đạt).
 - E002: “Xác minh tài khoản” — liên kết giả / lookalike (text≠href, miền “na ná”).
 - E003: “Hóa đơn thanh toán” — đính kèm macro (.docm).
- Pipeline kiểm tra: Header Analyzer → URL/Content Inspector → Attachment Policy → Risk Scorer.

6.1.2. Kết quả theo từng mẫu

ID	Kịch bản	Header (SPF/DKIM/DMARC; From↔Reply-To)	URL (text≠href;	Đính kèm	Điểm rủi ro	Mức rủi ro
----	----------	--	--------------------	-------------	-------------------	---------------

			IDN; lookalike)	(đuôi rủi ro)		
E00 1	Trúng thường (spoofing)	Fail/None; From≠Reply-To	—	—	≥5	HIGH
E00 2	Xác minh tài khoản (link giả)	Pass/không bất thường đáng kể	Mismatch + lookalike	—	≥5	HIGH
E00 3	Hóa đơn thanh toán (macro)	Pass/không bất thường đáng kể	—	.docm	≥5	HIGH

Với **mỗi kỹ thuật**, ít nhất **một mô-đun** bật cờ mạnh và đẩy điểm tổng lên ngưỡng **HIGH**.

6.1.3. Đóng góp theo từng mô-đun

- Header Analyzer: quyết định trong E001 (spoofing) nhờ SPF/DMARC fail + From≠Reply-To.
- URL/Content Inspector: quyết định trong E002 nhờ text≠href + lookalike (Levenshtein ~1–2).
- Attachment Policy: quyết định trong E003 nhờ phát hiện .docm (macro-enabled).

6.2. Phân tích sai số

Mặc dù demo đạt 100% trên bộ mẫu nhỏ, khi áp dụng thực tế sẽ gặp các nguồn dương tính giả (FP) và âm tính giả (FN) dưới đây:

6.2.1. Tình huống dễ FP

- Thư marketing hợp pháp dùng shortener hoặc theo dõi click → trùng quy tắc “URL rút gọn”.
- Danh sách thư/forwarder khiến Return-Path khác From → trùng quy tắc “From≠Reply-To/Return-Path”.
- Tập .zip chứa tài liệu nén (hợp lệ) → bị điểm trung bình/cao nếu không đọc được nội dung bên trong.
- Tên miền mới/hồi tổ (đúng thật) nhưng TLD lạ → cảnh báo nhẹ.

Giám FP đề xuất: thêm whitelist miền chính thống (ngân hàng, nhà trường, cơ quan), ghi nhận mô hình gửi hợp lệ (mailing list), và cho phép giảm trọng số với shortener của nhà cung cấp uy tín đã xác nhận.

6.2.2. Tình huống dễ FN (lọt lưới)

- IDN/homograph tinh vi dùng ký tự Unicode “khó thấy” (zero-width, lookalike sâu) → qua mặt kiểm tra đơn giản.
- Liên kết qua nhiều tầng chuyển hướng (SafeLinks/O365, tracking) làm mờ đích đến thực.
- Phishing không dùng link/tệp (yêu cầu trả lời thư, gửi OTP) → quy tắc URL/đính kèm ít tác dụng.
- Đính kèm PDF có script/embedded file: chỉ dựa vào đuôi sẽ không đủ.
- SPF/DKIM/DMARC pass nhưng nội dung lừa (tận dụng hộp thư hợp pháp bị xâm nhập).

Giảm FN đề xuất: tăng cường phân tích URL multi-hop, phát hiện Unicode bất thường, mở rộng danh mục mẫu nội dung rủi ro (đòi OTP/chuyển tiền), và thêm kiểm tra cấu trúc/mime của PDF.

6.3. Hạn chế của phiên bản hiện tại

1. Thuần heuristics, chưa học máy: không tự thích nghi theo dữ liệu mới; nhạy với thủ pháp né quy tắc.
2. Không truy vấn DNS/tiêu chuẩn trực tiếp: dựa vào Authentication-Results sẵn có; nếu header thiếu, khả năng suy luận giảm.
3. Không có sandbox động: không mở/tải để quan sát hành vi, nên chỉ “chặn sớm” ở mức tĩnh.
4. Không tích hợp Threat Intelligence (TI): chưa tra cứu domain/URL so với danh sách đen cộng đồng.
5. Chưa có GUI/plugin mail client: trải nghiệm CLI có thể khó với người dùng phi kỹ thuật.
6. Chưa có bộ dữ liệu đối chứng lớn: thiếu ước lượng FP/Precision trên thư hợp pháp từ nhiều nguồn.

6.4. Hướng phát triển

6.4.1. Nâng cấp phát hiện (kỹ thuật)

- DNS live check (tùy chọn có mạng): truy SPF/DKIM/DMARC, A/AAAA/CNAME/MX, kiểm tra alignment; cảnh báo khi domain không có

DMARC.

- OSINT/TI tích hợp: so đối chiếu với blocklist (domain, IP, TLD rủi ro), brand-abuse feed, phishing URL feeds.
- URL sandbox nhẹ: phân giải chuyển hướng nhiều tầng trong container cô lập, thu chỉ dấu tĩnh (tiêu đề, chứng chỉ, form).
- Bộ tính năng nâng cao: phát hiện Unicode mờ, data: URI, Base64 embed, HTML obfs (JS, meta refresh).
- Học máy nhẹ: logistic regression/gradient boosting trên đặc trưng URL + header + ngôn ngữ; calibrate threshold theo tập validation.

6.4.2. Nâng cấp trải nghiệm & vận hành

- GUI mini / Plug-in (Outlook/Thunderbird/Extension trình duyệt) để “soi nhanh” ngay trong giao diện e-mail.
- Cấu hình hoá rule/weights qua YAML/JSON; whitelist/brand list cập nhật định kỳ.
- Chế độ tổ chức: xuất JSON/CSV cho SIEM; webhook gửi cảnh báo; chính sách auto-quarantine với điểm HIGH.
- Bộ dữ liệu mở cho lớp học: thu thập e-mail hợp pháp ở nhiều ngữ cảnh (học thuật, ngân hàng, thương mại) → đo Precision/FP thực.

6.5. Quản trị rủi ro, đạo đức & quyền riêng tư

- Xử lý dữ liệu cục bộ: mặc định không gửi ra ngoài; nếu bật DNS/TI, chỉ gửi tối thiểu (host/domain đã bấm/ẩn danh).
- Ẩn danh hoá log: che tên người dùng, địa chỉ e-mail, token; cho phép bật chế độ không lưu (no-trace mode).
- Minh bạch & giải thích được: mỗi cảnh báo đi kèm lý do kỹ thuật, giúp người dùng học cách tự nhận diện.
- An toàn khi demo: chỉ dùng .eml giả lập, không truy/ mở nội dung độc hại; nếu cần minh hoạ AV, dùng chuỗi EICAR tiêu chuẩn.

KẾT LUẬN

Đề tài Mini Phishing Inspector theo đuổi mục tiêu rất thực tiễn: tạo ra một công cụ gọn nhẹ, có giải thích (explainable), giúp người dùng cuối “soi” nhanh e-mail trước khi lỡ tay nhấp hoặc mở đính kèm. Cách tiếp cận của nhóm bám sát ba trục rủi ro cốt lõi Header – URL – Đính kèm, ánh xạ trực tiếp sang các mắt xích quan trọng của kill chain (Delivery/Execution), nhờ đó đem lại giá trị chặn sớm rõ rệt trong bối cảnh học phần cũng như thực tế văn phòng.

Về kỹ thuật, bản mini đã hiện thực các kiểm tra có tác dụng lớn so với chi phí triển khai: so khớp From ↔ Reply-To/Return-Path, đọc kết quả SPF/DKIM/DMARC trong header; phát hiện IDN/Punycode, lookalike domain, liên kết rút gọn hoặc troj IP; đồng thời gắn cờ đuôi tệp rủi ro như .docm/.xlsm/.exe/.js.... Các quy tắc này đều xuất phát từ chỉ dấu phổ biến của phishing và được trình bày nhất quán trong thiết kế và demo.

Kết quả chạy thử trên bộ mẫu giả lập an toàn cho thấy công cụ đạt đúng kỳ vọng ở từng kịch bản điển hình, đồng thời vạch rõ hướng hoàn thiện tiếp theo: tinh chỉnh trọng số/whitelist để giảm FP, bổ sung kiểm tra DNS/multi-hop URL & threat-intel để hạ FN, và hướng tới ML nhẹ + GUI nhằm cải thiện trải nghiệm và khả năng tổng quát. Những bước nâng cấp này gắn chặt với phòng thủ đa lớp ở Chương 5 (gateway/endpoint/MFA), tạo thành chu trình “phát hiện → quyết sách → phản hồi” đồng bộ.

Ở tầm hệ thống, báo cáo đã liên kết thuyết phục giữa cảnh báo tĩnh ở máy người dùng (Mini Inspector) với chính sách lớp e-mail gateway, thói quen người dùng, hạ tầng mạng & danh tính (VPN, segment, MFA). Khi các lớp này phối hợp, xác suất thành công của phishing giảm mạnh và nếu có sự cố thì phạm vi/thiệt hại đều được khoanh vùng và khắc phục nhanh. Đây là nền tảng vững để mở rộng thử nghiệm trên dữ liệu thật, bổ sung mẫu “e-mail hợp pháp” để định lượng FP/FN, và tiến tới tích hợp GUI, log/export chuẩn phục vụ vận hành.

Tóm lại, đề tài đã: (i) hệ thống hóa kill chain & chỉ dấu kỹ thuật của e-mail phishing; (ii) hiện thực một bộ quy tắc phát hiện trọng yếu, dễ giải thích; (iii) chứng minh giá trị chặn sớm trên bộ mẫu; và (iv) đưa ra lộ trình nâng cấp gắn với phòng thủ đa lớp. Đây là một đóng góp phù hợp mục tiêu học phần, có tính ứng dụng ngay trong môi trường văn phòng/sinh viên, đồng thời mở đường cho những nghiên cứu tiếp theo theo hướng ML/threat-intel.

TÀI LIỆU THAM KHẢO

- [1] Kitterman, S. *RFC 7208: Sender Policy Framework (SPF) for Authorizing Use of Domains in Email*. IETF, 2014.
- [2] Crocker, D., et al. *RFC 6376: DomainKeys Identified Mail (DKIM) Signatures*. IETF, 2011.
- [3] Kucherawy, M., Zwicky, E. *RFC 7489: Domain-based Message Authentication, Reporting, and Conformance (DMARC)*. IETF, 2015
- [4] Bộ TT&TT (Cục ATTT). “Trò lừa mới đánh cắp dữ liệu cá nhân qua Gmail.” 2022.
- [5] Bộ TT&TT. “Cảnh báo 7 hình thức lừa đảo trực tuyến mới.” 2024.
- [6] Vietcombank. “Cảnh báo giả mạo.” 16/05/2024.
- [7] Vietcombank. “Cảnh báo mạo danh Vietcombank trong tuyển dụng.” 25/07/2024.
- [8] Cổng Thông tin điện tử Chính phủ. “Cảnh báo mạo danh Ngân hàng Nhà nước gửi đường link cập nhật sinh trắc học để lừa đảo.” 24/08/2024.
- [9] Tạp chí An toàn thông tin (Ban Cơ yếu CP). “Thủ đoạn tấn công lừa đảo (Phishing) với Microsoft Office.” 2023.
- [10] Tạp chí An toàn thông tin (Ban Cơ yếu CP). “Tấn công phishing với công cụ Evilginx: mối đe dọa tiềm tàng.” 23/02/2024.
- [11] Viettel Cyber Security (2023). Cảnh báo các hình thức tấn công lừa đảo có chủ đích. Truy cập tại: <https://blog.viettelcybersecurity.com>
- [12] Tenten (2020). Phishing email là gì? Cách phòng tránh email lừa đảo. Truy cập tại: <https://tenten.vn/tin-tuc/>